

Identity Security Health Check Checklist

The control checklist Link3IT works engagements against — across privileged access, cloud identity, directory, and governance. Use it to self-assess where your program stands before a formal review. Each unchecked box is a conversation worth having.

1 · Privileged Access (PAM)

- ☐ **All admin & service credentials are vaulted** — no privileged passwords in spreadsheets, scripts, or personal managers.
- ☐ **Rotation is automated and verified** — and you can prove the last successful rotation date for any managed account.
- ☐ **Reconciliation self-heals** — failed verifications trigger reconcile, not silent drift.
- ☐ **Tier-0 safe membership is minimal & named** — no nested-group sprawl into domain-admin credentials.
- ☐ **Privileged sessions are isolated & recorded** — activity on sensitive targets can be reconstructed for audit.

2 · Cloud Identity (Entra ID)

- ☐ **Legacy authentication is blocked** — so MFA cannot be bypassed via older protocols.
- ☐ **Conditional Access exclusions are audited** — every excluded identity is justified and reviewed.
- ☐ **Privileged roles use just-in-time (PIM)** — no standing Global Administrator assignments.
- ☐ **MFA coverage is verified, not assumed** — you can produce a coverage map on request.
- ☐ **Guest & external access is governed** — with expiry and review, not indefinite grants.

3 · Directory (Active Directory)

- ☐ **Privileged groups are trimmed** — Domain Admins and equivalents hold only who they must.
- ☐ **Service accounts resist Kerberoasting** — strong, rotated passwords or group-managed accounts.
- ☐ **Unconstrained delegation is removed** — or explicitly justified and constrained.

- ☐ **Stale & orphaned accounts are retired** — on a recurring cycle, not ad hoc.
-

4 · Governance (IGA)

- ☐ **Joiner-mover-leaver is automated** — from an authoritative HR source, with verified deprovisioning.
 - ☐ **Access is reviewed & certified regularly** — with evidence, not only when an audit forces it.
 - ☐ **Audit evidence is producible on demand** — mapped to a framework (NIST, CIS, ISO).
 - ☐ **Termination is verified end-to-end** — cloud sessions killed and vaulted creds rotated, not just the account disabled.
-

Scored fewer boxes than you'd like? That's normal — most environments clear maybe half on the first pass. A focused health check turns this list into a prioritized, risk-ranked roadmap specific to your environment. Start the conversation: asymister@link3it.com

© 2026 LJSTECH LLC · Link3IT. Provided as a self-assessment aid; not a substitute for a formal review.